



Savitribai Phule Pune University

Centre for Information and Network Security

Course: Introduction to Cyber Security / Information Security

Module 1: Pre-requisites in Information and Network Security

Chapter 1: Overview of Networking Concepts

Overview of Networking Concepts

Basics of Communication Systems

Communication has always been an integral part of human life. The dictionary meaning of 'communication' is: the activity or process of expressing ideas or feelings or of giving people information. It can be point to point that happens between only two entities like person to person or it can be point to multipoint that happens between one person to many like radio or television.

Over the period the means and ways of communication have evolved right from individual level to enterprise level. Nowadays communication systems have become backbone of today's world. Communication that happens over a long distance is called telecommunication. Radio, television, telephones are few traditional forms of telecommunication systems. With the advent of newer technologies like satellite communication and internet, telecommunication systems now are more efficient and reliable. They are capable of giving better quality of service to the users.

There are different components of communication system. It comprises of:

- a. **Sender (Source):**
He is the one who wants to send some message to the receiver.
- b. **Transmitter:**
The set of devices which converts the message in to a form that is suitable for transmission over designated medium.
- c. **Medium:**
Medium carries transmitted signal over a distance up to the receptor.
- d. **Receptor:**
It is the set of devices which catch the transmitted signal from the medium and convert it into the original message.
- e. **Receiver (Destination):** He is the one to whom the sender wants to send message.
- f. **Data:** The message that sender wants to send to the receiver.

The basic block diagram of communication system is as given below.



Sender who wants to send the data to receiver feeds the data to transmitter. Transmitter processes or encodes the data to generate signals which can propagate and carry the data over the medium. These signals are captured by the receptor at receiver end. Receptor decodes intercepted signals to generate original data and gives it to the receiver.

When two persons speak with each other, the sound produced by vocal chords is thrown out (transmitted) by the mouth cavity in the air. This produces sound waves in the air. The ears of another person become receptor of these waves and the meaning is interpreted by brain of that person.

In today's networked world there are varied technologies and means of telecommunication. The above diagram is the basic one and is applicable to any type of communication system. The complexity of each of the above mentioned component varies with the very purpose of the system and the end users of the system. For example, the system designed to allow long distance wireless communication of police is far different than DTH (Direct to Home) television broadcasting.

So far as communication using two computers is concerned, the system becomes more complicated.

Let us consider the example: While sitting in her home, Ms Tanvi from Pune is writing an email to Mr Umesh who is travelling in London. Both Umesh and Tanvi will need:

- Email accounts
- Internet connectivity
- User End devices: Laptop/Computer/Tab/smartphone

In this case, the computer that Tanvi is using, becomes the transmitter. Internet service providers (ISP) may use media (plural of medium) like wireless or cables or Optical Fibers to provide them internet connectivity. The email will be transferred through internet. If Umesh receives and read it using his smartphone, the smartphone becomes receptor here. This computer communication is accomplished by following special set of rules called protocols. Besides it there are few governing bodies which facilitate smooth functioning of computer communications.

In any communication system, the medium of communication decides how long the signal can be carried.

Transmission Media

In computer networks there are two types of media.

- a. Wired
- b. Wireless

Wired

Wired medium is a medium wherein physical connectivity is there between two nearby end points. The most common forms of wired media are:

- i. Twisted Pair Cable

In pair cables generally there are four pairs of copper wires bundled together in a plastic sheath. Each pair has different colour. The two copper wire of the pair are twisted and

enrolled on each other in a spiral form. This structure helps in minimising the interferences present in outer environment.

It is very common form of networking found in computer labs or small networks within the building.

These are generally called cat5/cat6 or Ethernet cables.

ii. Coaxial Cables:

It has a pair of conducting wires concentric to each other. The metal conductor is at the centre surrounded with the dielectric insulator. The circumferential outer conductor is placed on the dielectric. Braided sheath and outer jacket protects it from interferences and environments.

These cables can transfer higher frequency signals without losses upto considerably long distances than the twisted pair cables.

iii. Optical fibre:

Optical fibre cable (OFC) does not have metal conductor. It has thin glass conduits which transfers the signal in the form of light. The light rays pass through the inner glass. It has very high signal carrying capacity and hence used for high speed long distance connectivity.

Wireless:

As the name says, wireless network does not have any physical medium of communication. Electromagnetic radio frequency signals are used in such networks. The data to be carried is passed on to air using antenna and these signals are received at the destination.

Wi-Fi, Wi-Max are popular forms of wireless computer communication. Its range depends on the type and power of antenna and geography of the area. Buildings and similar obstructions attenuate the signal hampering the coverage. IEEE 802.11 standards describe various forms of such communication.

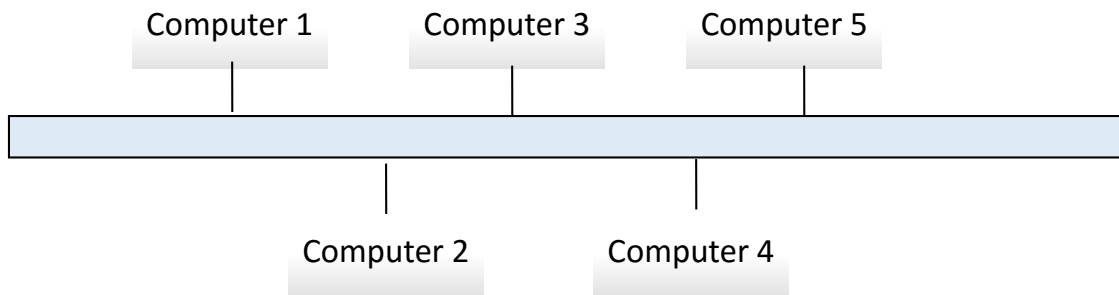
Network Topology

Network topology is the fashion in which computers (also called nodes) are connected in order to form a network.

Different topologies are

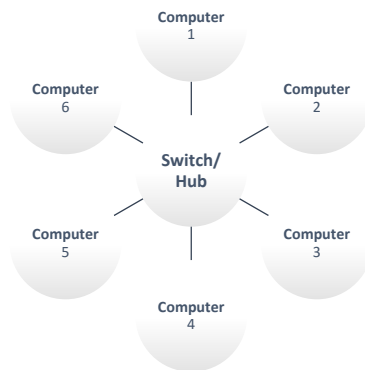
1. Bus topology

It is the simple topology in which computers are connected to common backbone. This common backbone is called trunk. It has terminator at one end. Only one computer can send the data in this topology.



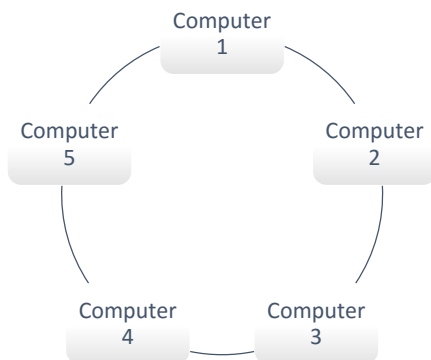
2. Star Topology

It has a central point (called hub) to which all the computers are connected. It involves more cabling. If the central unit stops functioning, entire network gets affected. More than one computer can send data in this type of topology.



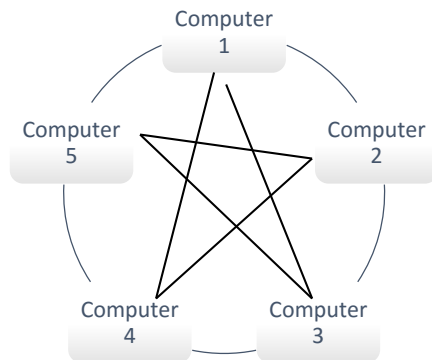
3. Ring topology

Computers are connected in ring fashion. Each computer acts as repeater and keeps passing the message over the ring. Failure of one node can affect the communication.



4. Mesh Topology:

Here each node is connected to all other nodes. Hence it gives better redundancy. If one segment connecting two different nodes fails, the communication can still happen through approaching the destination via different path.



5. Hybrid Topology:

It is mix of two or more topologies mentioned above. For example, a group of few nodes which are connected in star topology can be connected to few other nodes in a ring fashion.

Types of Networks

Computer networks can be small as in small offices having 4 to 5 computers or it can be large networks connecting thousands of computers spread over the city.

On the basis of the reach and scope, computer networks can be:

1. LAN (Local Area Network)
Local Area Network these are smaller networks limited to a building or small group of nearby buildings or campus.
2. MAN (Metropolitan Area Network)
These can have thousands of nodes and have a geographical spread across a big city. It may contain different smaller networks in it.
3. WAN (Wide Area Network)
These are bigger networks containing nodes, LANs and even MANs. WAN can spread across a state or even a nation.

As the size of the network increases, the complexity in its administration and monitoring also increases.

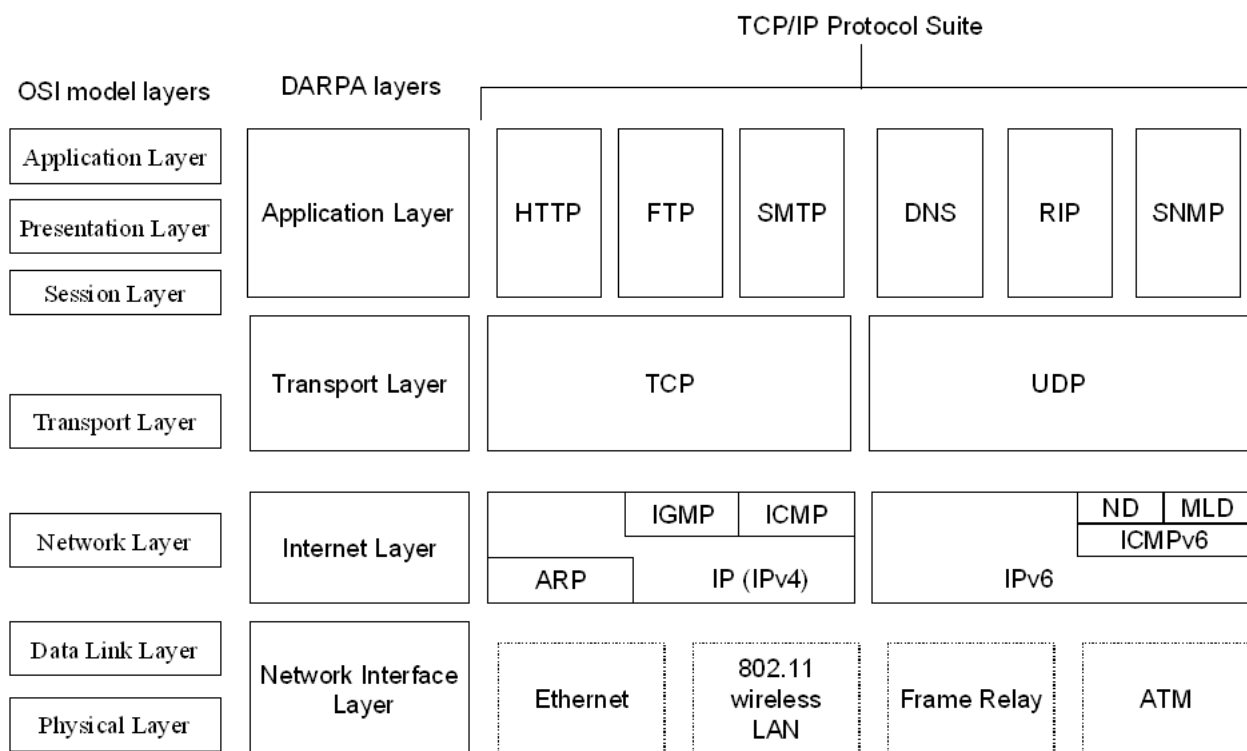
TCP/ IP protocol stack

TCP/IP stands for Transmission Control Protocol / Internet Protocol. It can almost be the synonym of today's internet communication.

As mentioned earlier, computer connections are established and communication happens using some set of rules called protocols. All the connecting networking devices and the end user devices are supposed to adhere to these protocols for efficient communication.

TCP/IP protocol stack is the suite of networking protocols which ensures the communication is error-free, accurate and reliable one.

Figure below shows the various protocols along with the logical layers. Each of these layers has a specific role to play in the overall communication and addresses specific issues as per the roles. For example: The physical layer is concerned with the physical medium through which the communicating nodes are connected. And Data link layer ensures physical connectivity along with error checking between two adjacent nodes.



Source: <https://technet.microsoft.com/en-us/library/bb726993.aspx>

Wireless Networks

Wireless networks connect different nodes on the network without using any wired media. This is implemented by using radio frequency (RF) signals. The data or message to be communicated is transformed into high electric oscillations which are propagated through air in the form of electromagnetic signals.

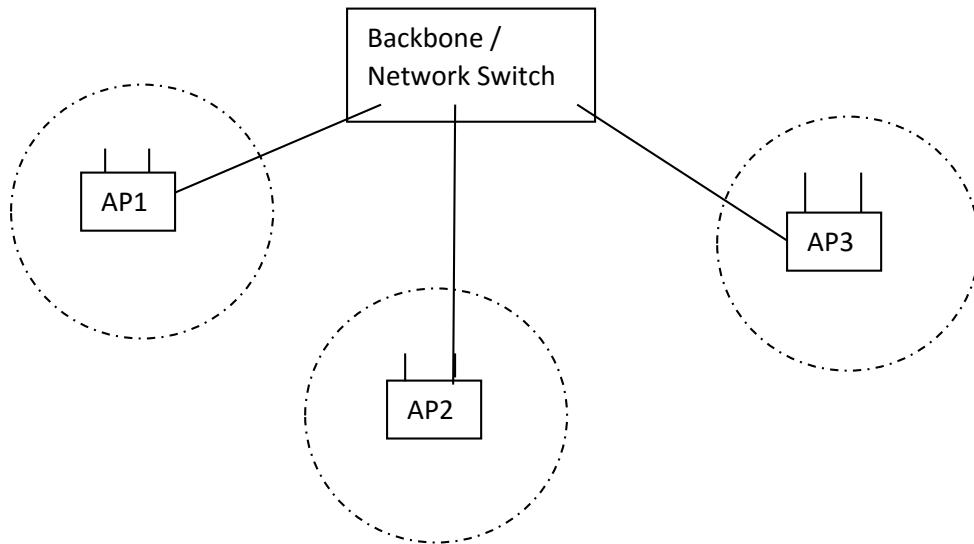
Access points (APs) are the main devices in wireless networks. AP converts the electric signal on wire into electromagnetic waves and transmits these waves into the air. Each AP zone can be identified with Service Set Identifier (SSID). SSID can also be treated as network names.

In a big wireless networks more than one APs are used. These APs are linked together through cable of another wireless signal. This linkage of APs is called backbone. Network name and the passwords are configured on the AP. In order to connect to the network, the settings on user's wireless device must match with the ones on the AP.

Wireless networks can be point-to-point (connecting two long distance points) or point-to-multipoint (connecting one point to many other points).

Wireless networks are highly scalable networks as no cabling is involved. At the same time these are more prone to security attacks as the signal on air can easily be intercepted by the attacker without physically accessing your network. For example: a wireless modem or router supplied by internet service provider (ISP) in a house may radiate the signal outside the house through windows or through walls.

IEEE802.11 set of standards explains various wireless sub-standards like IEEE802.11a, IEEE802.11b, IEEE802.11g, IEEE802.11n, IEEE802.11ac etc. Each of these standards have different features like speed of connectivity, operating frequency etc.



Internet

Internet is a global public network of interconnected computer networks linking billions of devices and nodes. It is called a network of networks. The interconnected networks can be private, public, educational, government or any other networks. Various protocols mentioned earlier in this chapter, few governing bodies and communities ensure efficiency and reliability of internet communication. IETF, ISOC, ICANN, IGF are few of the bodies which address the issues involved in internet.

Once connected to internet, the information available on various servers (high capacity computers which are mostly called web server on which website is hosted) on the internet can be accessed by using internet browsing tools and applications like internet explorer, Mozilla firefox, Google chrome or Apple safari.



Savitribai Phule Pune University

Centre for Information and Network Security

Course: Introduction to Cyber Security / Information Security

Module 1: Pre-requisites in Information and Network Security

Chapter 2: Information Security Overview: Background and Current Scenario

Types of Attack

Phishing:

Phishing is the attempt to acquire sensitive information such as usernames, passwords, and credit card details (and sometimes, indirectly, money), often for malicious reasons, by masquerading as a trustworthy entity in an electronic communication. Phishing takes advantage of the trust that the user may not be able to tell that the site being visited, or program being used, is not real; therefore, when this occurs, the hacker has the chance to gain the personal information of the targeted user, such as passwords, usernames, security codes, and credit card numbers, among other things.

Example: *Most methods of phishing use some form of technical deception designed to make a link in an email (and the spoofed website it leads to) appear to belong to the spoofed organization. Misspelled URLs or the use of subdomains are the common tricks used by phishers. In the following example URL, <http://www.yourbank.example.com/>, it appears as though the URL will take you to yourbank website; actually this URL points to a phishing site which looks as your original bank website. The user is then asked for his credentials by phishing website to gain sensitive information.*

Spoofing:

Spoofing is the creation of TCP/IP packets using somebody else's IP address. Routers use the "destination IP" address in order to forward packets through the Internet, but ignore the "source IP" address. That address is only used by the destination machine when it responds back to the source.

Example: *Hackers will use spoofing mechanism to avoid getting tracked by routers while making an attack.*

Impersonation

It is an act of pretending to be another person for the purpose of fraud. It can be done via any communication mechanism like phone, email etc.

Example: *An Impersonator calling victim and claims that he is calling from the bank where victim has account. He will ask for account details, passwords etc. in claiming that he is asking for the information for verification. In reality he will use the information to make fraudulent transactions.*

Dumpster Diving

In the computer world, dumpster diving refers to using various methods to get information about a technology user. In general, dumpster diving involves searching through trash or garbage looking for something useful. This is often done to uncover useful information that may help an individual get access to a particular network. So, while the term can literally refer to looking through trash, it is used more often in the context of any method (especially physical methods) by which a hacker might look for information about a computer network.

Goals for Security

The following are the key security goals

- Integrity - Making sure that the behavior of the system under test cannot be changed maliciously
- Confidentiality - Making sure that the system does not leak sensitive information and does not allow illegitimate users to access the system
- Non-repudiation - Ability of the system to be able to "prove" that certain actions actually happened
- Availability - Making sure that the system continues to remain available in the face of attacks
- Access Control - Users should not be allowed to perform actions beyond their permitted role

E-Commerce Security

Ecommerce entails buying/selling of products over the internet and has gain popularity in the recent years. Security is an essential part of any transaction that takes place over the internet. Customer will lose his/her faith in e-business if its security is compromised. Following are the essential requirements for safe ecommerce website:

1. Choose a secure ecommerce platform: Choose a strongly typed higher level language for the development. If open source tools/libraries are used then ensure that the frameworks does not create security holes in your application
2. Use a secure connection for online checkout--and make sure you are PCI compliant: Always use HTTPs protocol for all important transactions.
3. Don't store sensitive data: As part of the website, there is no need to store sensitive information like CVV number and other credit card information
4. Set up system alerts for suspicious activity: Build a system that alerts when an undesired event happens in the system. Multiple requests from the same IP for long periods of time can indicate malicious intent
5. Layer your security: Defense in depth is absolutely needed in ecommerce domain. Security features like multiple passwords and OTP helps in reducing the risk of hacking
6. Provide security training to employees: If the employees understand the importance of security then human error can be avoided
7. Patch your systems: New security loop holes are discovered on a daily basis. If the system is not up to date then risk of getting hacked increases exponentially
8. Make sure you have a Distributed Denial of Service (DDoS) protection and mitigation service: Have a mitigation strategy against network denial of service attack and block IPs that are sending lot of request to the system
9. Disaster recovery plan: Plan for unlikely failure of your system. In case of system failure ensure that sensitive data is not lost or corrupted by the system

Computer Forensics

Computer forensics is a branch of digital forensic science pertaining to evidence found in computers and digital storage media. The goal of computer forensics is to examine digital media in a forensically sound manner with the aim of identifying, preserving, recovering, analyzing and presenting facts and opinions about the digital information

At a high level following are the guidelines used to process the evidence in computer forensic:

- Step 1: Shut down the computer. Considerations must be given to volatile information. Prevents remote access to machine and destruction of evidence (manual or anti-forensic software)
- Step 2: Document the Hardware Configuration of the System. Note everything about the computer configuration prior to re-locating
- Step 3: Transport the Computer System to A Secure Location. Do not leave the computer unattended unless it is locked in a secure location
- Step 4: Make Bit Stream Backups of Hard Disks and Floppy Disks
- Step 5: Mathematically Authenticate Data on All Storage Devices. Must be able to prove that you did not alter any of the evidence after the computer came into your possession
- Step 6: Document the System Date and Time
- Step 7: Make a List of Key Search Words
- Step 8: Evaluate the Windows Swap File
- Step 9: Evaluate File Slack. File slack is a data storage area of which most computer users are unaware; a source of significant security leakage.
- Step 10: Evaluate Unallocated Space (Erased Files)
- Step 11: Search Files, File Slack and Unallocated Space for Key Words
- Step 12: Document File Names, Dates and Times
- Step 13: Identify File, Program and Storage Anomalies
- Step 14: Evaluate Program Functionality
- Step 15: Document Your Findings
- Step 16: Retain Copies of Software Used

Where Computer forensic is used?

- a. Criminal prosecution
- b. Insurance companies
- c. Law enforcement

Steganography

Steganography is the practice of concealing a file, message, image, or video within another file, message, image, or video. For example, the hidden message may be in invisible ink between the visible lines of a private letter.

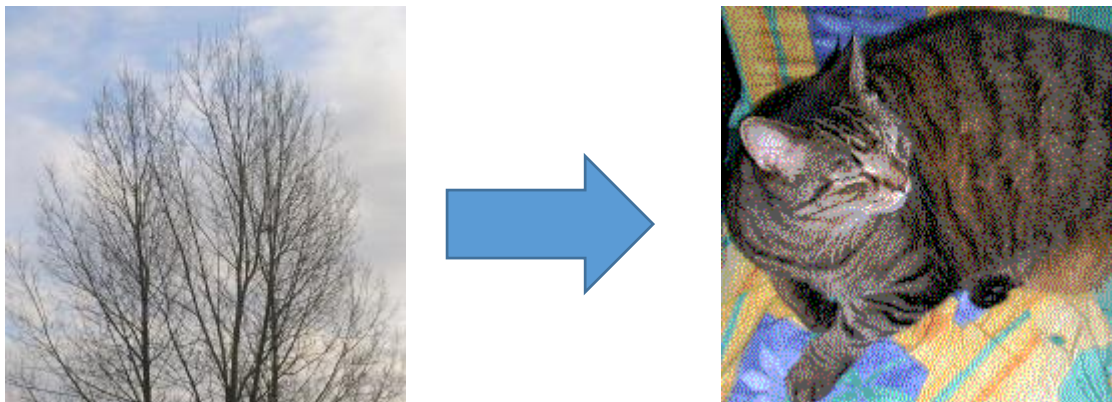
The advantage of steganography over cryptography alone is that the intended secret message does not attract attention to itself as an object of scrutiny. Plainly visible encrypted messages—no matter how unbreakable—arouse interest, and may in themselves be incriminating in countries where encryption is illegal. Thus, whereas cryptography is the practice of protecting the contents of a message alone,

steganography is concerned with concealing the fact that a secret message is being sent, as well as concealing the contents of the message.

Some of the earlier examples of steganography are:

- Hidden messages on messenger's body—also used in ancient Greece. Herodotus tells the story of a message tattooed on the shaved head of a slave of Histiaeus, hidden by the hair that afterwards grew over it, and exposed by shaving the head. The message allegedly carried a warning to Greece about Persian invasion plans. This method has obvious drawbacks, such as delayed transmission while waiting for the slave's hair to grow, and restrictions on the number and size of messages that can be encoded on one person's scalp.
- In the early days of the printing press, it was common to mix different typefaces on a printed page due to the printer not having enough copies of some letters in one typeface. Because of this, a message could be hidden using two (or more) different typefaces, such as normal or italic.

In digital steganography, electronic communications may include steganographic coding inside of a transport layer, such as a document file, image file, program or protocol. Media files are ideal for steganographic transmission because of their large size. For example, a sender might start with an innocuous image file and adjust the color of every 100th pixel to correspond to a letter in the alphabet, a change so subtle that someone not specifically looking for it is unlikely to notice it.



Source: <https://en.wikipedia.org/wiki/Steganography>

The above is a classic example of steganography where the left tree image is hiding the right image and the hidden image is revealed by removing all but the two least significant bits of each color component and a subsequent normalization.



Savitribai Phule Pune University

Centre for Information and Network Security

Course: Introduction to Cyber Security / Information Security

Module 1: Pre-requisites in Information and Network Security

Chapter 3: Security Threats and Vulnerabilities

1. Basics of threat and vulnerability

In computer security a **threat** is a possible danger that might exploit a vulnerability to breach security and thus cause possible harm.

A **vulnerability** is a weakness which allows an attacker to reduce a system's information assurance. Vulnerability is the intersection of three elements: a system susceptibility or flaw, attacker access to the flaw, and attacker capability to exploit the flaw.

An example of a natural threat is the occurrence of a hurricane. Depending on the geographic location of the entity, the likelihood of that occurrence could be low, medium, or high, and one of the risks associated with the occurrence may be that the power could fail and the information systems could be unavailable. Based on the assessment conducted, the organization should develop a strategy to manage the risks associated with the potential of such a threat. So what is the vulnerability in the above example?

The vulnerability is us, humans. That we are fragile and cannot withstand strong winds. That we are dependent on natural as well as artificial resources to survive.

You can group threats into categories to help you formulate these kinds of pointed questions. One model you may find useful is STRIDE, derived from an acronym for the following six threat categories:

- **Spoofing identity.** An example of identity spoofing is illegally accessing and then using another user's authentication information, such as username and password.
- **Tampering with data.** Data tampering involves the malicious modification of data. Examples include unauthorized changes made to persistent data, such as that held in a database, and the alteration of data as it flows between two computers over an open network, such as the Internet.
- **Repudiation.** Repudiation threats are associated with users who deny performing an action without other parties having any way to prove otherwise—for example, a user performs an illegal operation in a system that lacks the ability to trace the prohibited operations. Nonrepudiation refers to the ability of a system to counter repudiation threats. For example, a user who purchases an item might have to sign for the item upon receipt. The vendor can then use the signed receipt as evidence that the user did receive the package.
- **Information disclosure.** Information disclosure threats involve the exposure of information to individuals who are not supposed to have access to it—for example, the ability of users to read a file that they were not granted access to, or the ability of an intruder to read data in transit between two computers.
- **Denial of service.** Denial of service (DoS) attacks deny service to valid users—for example, by making a Web server temporarily unavailable or unusable. You must protect against certain types of DoS threats simply to improve system availability and reliability.
- **Elevation of privilege.** In this type of threat, an unprivileged user gains privileged access and thereby has sufficient access to compromise or destroy the entire system. Elevation of privilege threats include those situations in which an attacker has effectively penetrated all system defences and become part of the trusted system itself, a dangerous situation indeed

Let's take a bank example to see how threats are categorized, here is a list of uncategorized threats for you, please put them in their respective categories:

1. If somebody is able to transfer money with my consent but I am not able to see who and how much he/she has transferred money from my account
2. If I transfer Rs.100 to another account every time more/less than Rs. 100 is deducted from my account
3. I as an user is not able to access a particular part of web application
4. A malicious user is able to change my account balance
5. Any other person is able to see how much balance I have in my account
6. A malicious user is able to change my email address and password

Answer:

Spoofing Identity: (6)

Information disclosure: (5)

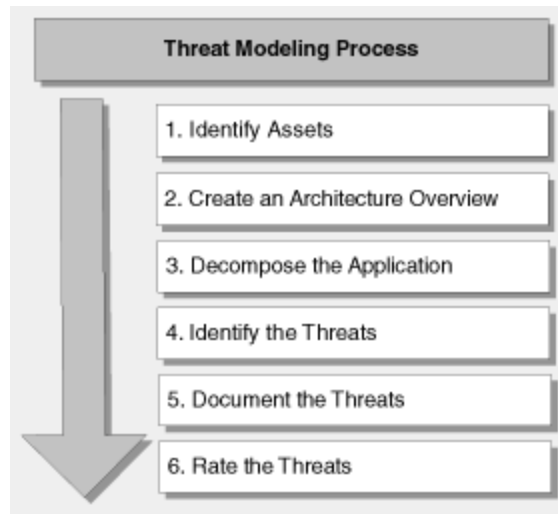
Tampering of data: (2)

Denial of Service: (3)

Repudiation: (1)

Elevation of privilege: (4)

2. How to do identify threats through threat modelling?



Source: <https://msdn.microsoft.com/en-us/library/ff648644.aspx>

An overview of the threat modeling process

1. **Identify assets.**

Identify the valuable assets that your systems must protect. Example: Confidential data, such as customer databases

2. **Create an architecture overview.**

Use simple diagrams and tables to document the architecture of your application, including subsystems, trust boundaries, and data flow.

3. **Decompose the application.**

Decompose the architecture of your application, including the underlying network and host infrastructure design, to create a security profile for the application. The aim of the security profile is to uncover vulnerabilities in the design, implementation, or deployment configuration of your application.

4. **Identify the threats.**

Keeping the goals of an attacker in mind, and with knowledge of the architecture and potential vulnerabilities of your application, identify the threats that could affect the application.

5. **Document the threats.**

Document each threat using a common threat template that defines a core set of attributes to capture for each threat.

6. Rate the threats.

Rate the threats to prioritize and address the most significant threats first. These threats present the biggest risk. The rating process weighs the probability of the threat against damage that could result should an attack occur. It might turn out that certain threats do not warrant any action when you compare the risk posed by the threat with the resulting mitigation costs

As said earlier threats arises due to presence of vulnerabilities, let's take a look at few of the common security problems of IT and threats associated with them

3. Weak/Strong password and Password Cracking

Now-a-days passwords are the most important asset in any application. It is the key through which the application identifies the user and allows them to do their respective actions. If a malicious user is able to guess/retrieve your password then he is control of your data, information and in general existence.

So, what are the attributes of a strong password?

- Contains both upper and lower case characters
- Includes digits and punctuation characters as well as letters (!@#\$%^&*()_+|~-=`{}[]:~';<>?,./)
- Has at least eight characters
- Does not contain a word in any language, slang, dialect, jargon, etc.
- Is not based on personal information, names of family, etc.

And weak password?

- Contains less than eight characters
- Is a word found in a dictionary (English or foreign)
- Is a common usage word such as: Names of family, pets, friends, co-workers, fantasy characters, etc.
- Computer terms and names, commands, sites, companies, hardware, software, sport team
- Birthdays and other personal information such as addresses, phone numbers, or license plates
- Word or number patterns like aaabbb, qwerty, 9876543
- Any of the above spelled backwards.
- Any of the above preceded or followed by a digit (battleship52)

The user needs to create a strong password to avoid password cracking which is one of the foremost ways of hacking as it is very easy to do and provides complete control over the victim. So what is password cracking?

The time to crack a password is related to password strength, which is a measure of the password's information entropy, and the details of how the password is stored. Most methods of password cracking require the computer to produce many candidate passwords, each of which is checked. One example is brute-force cracking, in which a computer tries every possible key or password until it succeeds. More common methods of password cracking, such as dictionary attacks, pattern checking, word list substitution, etc. attempt to reduce the number of trials required and will usually be attempted before brute force.

Password Length	All Characters	Only Lowercase
3 characters	0.86 seconds	0.02 seconds
4 characters	1.36 minutes	.046 seconds
5 characters	2.15 hours	11.9 seconds
6 characters	8.51 days	5.15 minutes
7 characters	2.21 years	2.23 hours
8 characters	2.10 centuries	2.42 days
9 characters	20 millennia	2.07 months
10 characters	1,899 millennia	4.48 years
11 characters	180,365 millennia	1.16 centuries
12 characters	17,184,705 millennia	3.03 millennia
13 characters	1,627,797,068 millennia	78.7 millennia
14 characters	154,640,721,434 millennia	2,046 millennia

Source: <http://lifel hacker.com/5505400/how-id-hack-your-weak-passwords>

4. Insecure Network connections

Through insecure network connection, the hacker will be able to get sensitive information over the network like username/password, browsing history, usage pattern etc.

The following are the characteristics of a non-secure network communication:

1. Non-Https communication where sensitive data is sent over the network with any kind of encryption
2. Unsecured firewalls where unnecessary ports are still opened and can be used to attack the system
3. Local digital certificates are used by websites which can be easily duplicated resulting in phishing attacks
4. Improper network connection where the host is connected to network which is not secured and created for a malicious intent. Example free wifi systems
5. Application Layer problems in which the application is built incorrectly and allows sensitive information to be leaked. Example of username and password in the url of a website

5. Malicious Code

Malicious code is the term used to describe any code in any part of a software system or script that is intended to cause undesired effects, security breaches or damage to a system. Malicious code describes a broad category of system security terms that includes attack scripts, viruses, worms, Trojan horses, backdoors, and malicious active content.

Computer viruses are still the most common form of malicious code. A virus is a program that infects a computer by attaching itself to another program, and propagating itself when that program is executed.

Another frequently encountered malicious code is the worm, which is a computer program that can make copies of itself, spreading through connected systems and consuming resources on affected computers or causing other damage.

Some malicious codes, including most viruses, are fragments of programs that cannot exist alone and need to attach themselves to host programs. Other types of malicious code are able to spread and replicate by themselves (such as worms) and are able to propagate from computer to computer across a network.

6. Programming Bugs

Vulnerabilities also arises due to programming flaws, some of the common flaws are given below:

6.1 Improper Input Validation

Ensure that your input is valid. If you're expecting a number, it shouldn't contain letters. Nor should the price of a new car be allowed to be a dollar. Incorrect input validation can lead to vulnerabilities when attackers can modify their inputs in unexpected ways. Many of today's most common vulnerabilities can be eliminated, or at least reduced, with strict input validation.

6.2 Improper Encoding or Escaping of Output

Insufficient output encoding is at the root of most injection-based attacks. An attacker can modify the commands that you intend to send to other components, possibly leading to a complete compromise of your application - not to mention exposing the other components to exploits that the attacker would not be able to launch directly. When your program generates outputs to other components in the form of structured messages such as queries or requests, be sure to separate control information and metadata from the actual data.

6.3 Error Message Information Leak

Chatty error messages can disclose secrets to any attacker who misuses your software. The secrets could cover a wide range of valuable data, including personally identifiable information (PII), authentication credentials, and server configuration. They might seem like harmless secrets useful to your users and admins, such as the full installation path of your software -- but even these little secrets can greatly simplify a more concerted attack.

6.4 Failure to Constrain Operations within the Bounds of a Memory Buffer

The scourge of C applications for decades, buffer overflows have been remarkably resistant to elimination. Attack and detection techniques continue to improve, and today's buffer overflow variants aren't always obvious at first or even second glance.

6.5 Improper Access Control (Authorization)

If you don't ensure that your software's users are only doing what they're allowed to, then attackers will try to exploit your improper authorization and exercise that unauthorized functionality.

6.6 Hard-Coded Password

Hard-coding a secret account and password into your software is extremely convenient -- for skilled reverse engineers. If the password is the same across all your software, then every customer becomes vulnerable when that password inevitably becomes known. And because it's hard-coded, it's a huge pain to fix.

6.7 Execution with Unnecessary Privileges

Your software may need special privileges to perform certain operations; wielding those privileges longer than necessary is risky. When running with extra privileges, your application has access to resources that the application's user can't directly reach. Whenever you launch a separate program with elevated privileges, attackers can potentially exploit those privileges.

Cybercrime and cyber terrorism:

Cyber terrorism is the use of Internet based terror attacks, done deliberately in order to create disturbances or havoc in usual working of the internet. Since, many computers are connected through internet, the chances of high disruption in computer related services in personal as well commercial devices. Attacks through cyber terrorism can be in form of various illegal activities whose number is on a constant increase, a few are most lethal and common. These include attacks from viruses, attacks from Trojans, attacks from BOTS, attacks on databases, black hat hacking etc.

Example:

The MyDoom (or Novarg) virus is another worm that can create a backdoor in the victim computer's operating system. The original MyDoom virus -- there have been several variants -- had two triggers. One trigger caused the virus to begin a denial of service (DoS) attack starting Feb. 1, 2004. The second trigger commanded the virus to stop distributing itself on Feb. 12, 2004. Even after the virus stopped spreading, the backdoors created during the initial infections remained active [source: Symantec].

Later that year, a second outbreak of the MyDoom virus gave several search engine companies grief. Like other viruses, MyDoom searched victim computers for e-mail addresses as part of its replication process. But it would also send a search request to a search engine and use e-mail addresses found in the search results. Eventually, search engines like Google began to receive millions of search requests from corrupted computers. These attacks slowed down search engine services and even caused some to crash [source: Sullivan].

MyDoom spread through e-mail and peer-to-peer networks. According to the security firm MessageLabs, one in every 12 e-mail messages carried the virus at one time [source: BBC]. Like the Klez virus, MyDoom could spoof e-mails so that it became very difficult to track the source of the infection

Information warfare and Surveillance:

Surveillance is the monitoring of the behaviour, activities, or other changing information, usually of people for the purpose of influencing, managing, directing, or protecting them.

The vast majority of computer surveillance involves the monitoring of data and traffic on the Internet. In the United States for example, under the Communications Assistance For Law Enforcement Act, all phone calls and broadband Internet traffic (emails, web traffic, instant messaging, etc.) are required to be available for unimpeded real-time monitoring by Federal law enforcement agencies.

There is far too much data on the Internet for human investigators to manually search through all of it. So automated Internet surveillance computers sift through the vast amount of intercepted Internet traffic and identify and report to human investigators traffic considered interesting by using certain "trigger" words or phrases, visiting certain types of web sites, or communicating via email or chat with suspicious individuals or groups. Billions of dollars per year are spent, to intercept and analyse all of this data, and extract only the information which is useful to law enforcement and intelligence agencies.

Computers can be a surveillance target because of the personal data stored on them. If someone is able to install software, such as the FBI's Magic Lantern and CIPAV, on a computer system, they can easily gain unauthorized access to this data. Such software could be installed physically or remotely

References:

- <https://en.wikipedia.org>
- <http://www.hhs.gov/>
- [https://msdn.microsoft.com/en-us/library/ee823878\(v=cs.20\).aspx](https://msdn.microsoft.com/en-us/library/ee823878(v=cs.20).aspx)
- <https://msdn.microsoft.com/en-us/library/ff648644.aspx>
- https://en.wikipedia.org/wiki/Password_strength
- https://www.npdn.org/infosec_pw_strong
- http://www.infosec.gov.hk/english/virus/geninfo_what.html
- <http://blog.codinghorror.com/top-25-most-dangerous-programming-mistakes/s>
- <http://readanddigest.com/what-is-cyber-terrorism/>
- <http://computer.howstuffworks.com/worst-computer-viruses.htm#page=7>
- <https://en.wikipedia.org/wiki/Surveillance>



Savitribai Phule Pune University

Centre for Information and Network Security

Course: Introduction to Cyber Security / Information Security

Module 1: Pre-requisites in Information and Network Security

Chapter 4: Cryptography / Encryption

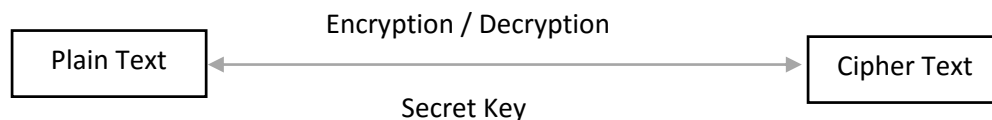
Introduction to Cryptography

Cryptography comes from Greek *kryptos* means "hidden, secret"; and *gráphō*, "I write" respectively. It is the practice and study of hiding information. It is the science used to try to keep information secret and safe.

Confidentiality is one of the three core principles of information security. The aim of confidentiality is to ensure that information is hidden from people who are unauthorized to access it. The confidentiality principle mandates that information should solely be viewed by people with appropriate and correct privileges. It is achieved either by authorization / authentication i.e. providing right access and validating it at the time of accessing information or by cryptography, which involves **encryption** and **decryption** methods.

Encryption

The process of converting a plain text message into a *cipher text* message i.e. non-readable format with the help of a *secret key* is called encryption and converting *cipher text* to plain text is called decryption.



Types of Encryption

Symmetric Encryption: In this type of Encryption, both sender and receiver will use same key to Encrypt and Decrypt information. In the absence, of the secret key a third person will not be able to read the information.

E.g. Suman wants to send confidential information to Kirti. Both Suman and Kirti will have access to same Secret Key.

Suman –Encrypt - *Secret Key* (Plaintext) = Ciphertext

Kirti – Decrypt - *Secret Key* (Ciphertext) = Plaintext

Assymmetric Encryption: In this type of Encryption, a pair of keys known as Public Key and Private Key is used. As name indicates, Public Key is shared and known to everyone where as Private Key is with the person himself.

Sender while Encrypting will use Receiver's Public Key and encrypt the message whereas Receiver will use his/her Private Key to decrypt the message and read it.

Suman – Encrypt – [*Public Key* - Kirti] (Plaintext) = CipherText

Kirti – Decrypt - [*Private Key* – Kirti] (CipherText) = Plaintext

It is apparent that secret key is very important in both the cases. So how do Suman and Kirti share Secret Key with each other?

How to share Secret Key?

For symmetric encryption, the private key needs to be shared between both the communicating parties and there are multiple mechanisms like *Diffie Hellman* and *RSA* to achieve that. These mechanisms use asymmetric key i.e. Public Key Infrastructure to share the *Secret Key*.

Digital Certificate

Now, you would think how to discover Public Key of others? The answer is *Digital Certificate*. A *Digital Certificate* contains information about its owner like name, Public Key, Validity of certificate etc. All the browsers recognize Digital Certificates and will download them automatically. They will extract the Public Key to decrypt the message before they show the content to the receiver. Hence, Digital Certificates is commonly used mechanism to share Public Key with each other.

Now, next problem is how to determine that the public key and the certificate belong to the user they claim to belong to. Public Key Infrastructure (PKI) is the answer to this problem.

Public Key Infrastructure

A public key infrastructure (PKI) is a set of hardware, software, people, policies, and procedures needed to create, manage, distribute, use, store, and revoke digital certificates and manage public-key encryption.;

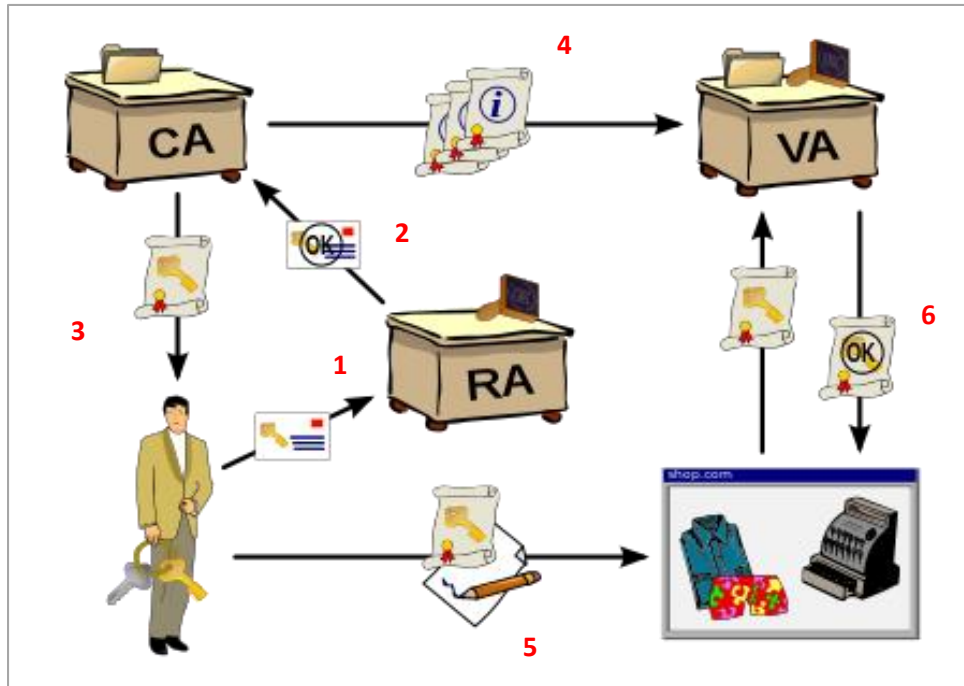
There are 3 key roles in PKI as below:

Certificate Authority (CA): A Certificate Authority issues digital certificates to person or organization which requests for it. In many cases, it will also play role of Verification Authority (VA) and verify the digital certificates.

E.g. Here are some of *Comodo*, *Symantec*, *GoDaddy*, *GlobalSign*, *DigiCert*

Registration Authority (RA): Registration Authority is responsible for accepting requests for digital certificates and authenticating the person or organization making the request. This authority will verify identity of person / organization and ensure that person / organization is what it is claiming.

Validation Authority (VA): A Validation Authority (VA) is an organization which verifies the digital certificates. It is often a 3rd party organization i.e. a separate organization than CA or RA.



Source: https://en.wikipedia.org/wiki/Public_key_infrastructure

1. User sends required information to Registration Authority.
2. Registration Authority verifies provided information & if found OK then registers user and shares OK report with Certificate Authority
3. Certificate Authority shares Public & Private Key with the user
4. Certificate Authority shared Public & Private Key with Validation Authority as well
5. While shopping, user will initiate transaction encrypted with his Private Key
6. Shopping website will share the Key information shared by user with Validation Authority. VA will validate it & if found to be correct then validate and authorize transaction.

Applications of Cryptography

Cryptography is used in many of the common activities in our daily lives. Below are some of the activities where cryptography is used:

1. **Authentication Services:** Authentication is a process of confirming that the user is what he/she is claiming to be.
E.g. User Name/ Passwords: Storing and transmitting passwords used for authentication of users.
2. **E-mail:** Email is one of the most common mode of communication in today's world. It is used to share confidential / important information between two individuals / organizations. Security issues with email programs surfaced early in their lifecycle. The vendors of email programs realized that they would have to figure out a way for everyone to be able to send *secure* email.

That is, e-mail in some sort of coded or encrypted form. It only made sense that this new feature be standardized, so they created *S/MIME* — Secure Multipurpose Internet Mail Extensions.

3. **E-Commerce** – E-commerce portals handle user information, bank /card information, passwords etc. hence it is necessary that this information is securely transmitted from user to the portal, from portal to 3rd party systems & back.

Typically, these portal use Transport Layer Security (TLS)/ Secure Sockets Layer (SSL) protocols. The TLS/SSL protocols help prevent communications eavesdropping, tampering, and forgery. Web servers and browsers use the TLS handshake to authenticate each other and to negotiate an encryption algorithm and cryptographic keys before transmitting data. The TLS handshake uses public key cryptography, such as RSA or DSS, to authenticate computers and to negotiate a shared secret. Of course, Digital Certificates are also used.

TLS uses symmetric cryptography, such as DES or RC4, to encrypt the data, such as credit card numbers, prior to transmission over the network. Any message transmissions include a message authentication code (MAC) created with a hash function such as SHA or MD5 to prevent any communications tampering and forgery.